

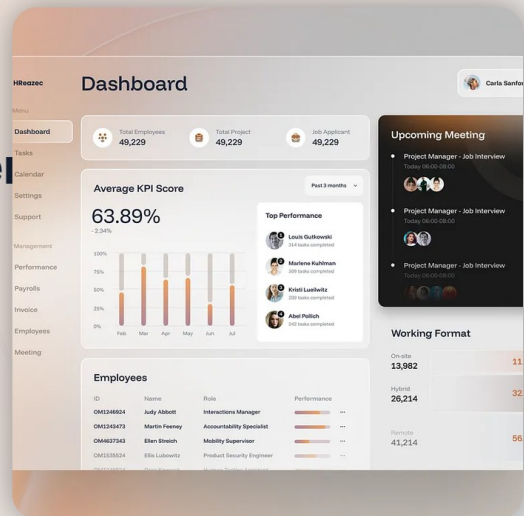


PRD + DISCOVERY

Plataforma de gerenciamento para servidores WordOps

Produto, UX/UI, arquitetura, segurança, APIs, backlog e prompt mestre de implementação.

VERSÃO 1.0 • 29 JUL 2026



Referência visual: dashboard glassmorphism enviado pelo cliente

Controle do documento

Campo	Definição
Produto	OpsPanel (nome provisório) - painel web para administrar servidores e sites gerenciados por WordOps.
Versão	1.0 - discovery consolidada e especificação para prototipação e engenharia.
Data	29 de julho de 2026.
Status	Base recomendada para orçamento, design de alta fidelidade, arquitetura e início do desenvolvimento.
Público	Product manager, UX/UI designer, tech lead, backend, frontend, DevOps/SRE, QA e stakeholders.
Premissa central	Control plane multi-servidor com agente local seguro; nenhuma execução de shell arbitrária a partir do navegador.
Implantação	Arquitetura preparada para SaaS multi-tenant ou instalação self-hosted; MVP pode iniciar single-tenant e multiusuário.

Leitura recomendada

As seções 1 a 8 definem o produto e a experiência. As seções 9 a 16 orientam engenharia e operação. Os apêndices transformam a especificação em backlog, contratos e prompt pronto para ferramentas de desenvolvimento assistido por IA.

Índice executivo

- 1. Resumo executivo
- 2. Contexto, problema e discovery
- 3. Usuários, personas e Jobs to Be Done
- 4. Escopo, releases e prioridades
- 5. Requisitos funcionais completos
- 6. Fluxos críticos e critérios de aceite
- 7. Arquitetura de informação e mapa de telas
- 8. Direção UX/UI e design system glassmorphism
- 9. Arquitetura técnica recomendada
- 10. Modelo de domínio e dados
- 11. API, agente e orquestração de jobs
- 12. Segurança, privacidade e LGPD
- 13. Requisitos não funcionais
- 14. Observabilidade, suporte e operação
- 15. Estratégia de testes e qualidade
- 16. Deploy, CI/CD e ambientes
- 17. Métricas de produto e SLOs
- 18. Roadmap e backlog priorizado
- 19. Riscos e mitigação
- 20. Critérios de lançamento e Definition of Done
- 21. Decisões em aberto
- 22. Prompt mestre de implementação
- Apêndices A-C: mapa WordOps, payloads, glossário e fontes.

1. Resumo executivo

OpsPanel é um control plane visual para transformar operações de WordOps - hoje executadas principalmente por CLI - em fluxos guiados, seguros, auditáveis e acessíveis a equipes que não precisam trabalhar diretamente por SSH.

A plataforma centraliza múltiplos servidores, detecta suas capacidades, importa sites existentes e permite criar, alterar, proteger, acompanhar e remover sites por meio de jobs assíncronos. O produto deve preservar o poder do WordOps sem transformar o painel em uma shell web: cada ação é uma operação tipada, validada, com preview, lock, logs redigidos, verificação final e trilha de auditoria.

O MVP deve resolver com excelência quatro tarefas: conectar um servidor WordOps; visualizar saúde e inventário; criar um novo site escolhendo tipo, cache, PHP, WordPress e SSL; e administrar alterações recorrentes como versão de PHP, cache, certificado e usuário de acesso a arquivos. Backups pré-operação, controle de acesso, logs e segurança não são acessórios: fazem parte do núcleo mínimo confiável.

Decisão de arquitetura mais importante

Use um agente local instalado em cada servidor. O agente mantém conexão outbound com o control plane, executa somente comandos catalogados e reporta estado. Evite manter senhas SSH permanentes no painel e não exponha uma porta de administração do agente à internet.

1.1 Proposta de valor

Para	Problema atual	Valor entregue
Agências e times web	Operações repetitivas por SSH, dependência de poucas pessoas e risco de erro.	Provisionamento guiado, padronização, histórico e delegação segura.
DevOps / administrador	Baixa visibilidade de múltiplos servidores e mudanças sem rastreabilidade.	Inventário reconciliado, jobs, locks, logs, métricas e auditoria.
Desenvolvedor	Precisa solicitar mudanças simples ou receber acesso amplo demais.	Ações de site com escopo mínimo e acesso de arquivos isolado.
Gestor	Não sabe capacidade, estado, volume de sites ou incidentes.	Dashboard operacional com saúde, riscos, falhas e atividade.

1.2 Objetivos de negócio e produto

- **Reduzir tempo operacional.** Criar e configurar sites em minutos, com menos etapas manuais e menor dependência de conhecimento de terminal.
- **Reduzir risco.** Bloquear combinações inválidas, exigir confirmações para ações destrutivas e manter backups e logs verificáveis.
- **Aumentar escala.** Permitir que uma equipe administre dezenas de servidores e centenas ou milhares de sites a partir de uma visão única.
- **Transformar conhecimento em produto.** Codificar boas práticas de WordOps, segurança, SSL, PHP, cache e acesso em fluxos consistentes.
- **Preparar monetização.** Arquitetura multi-tenant-ready, com limites, planos e métricas de uso possíveis no futuro, sem obrigar um SaaS no MVP.

1.3 Não objetivos do MVP

- Oferecer terminal SSH arbitrário dentro do navegador.
- Substituir o WordOps, reimplementar Nginx/PHP/MariaDB ou manter um fork do projeto.
- Virar painel de hospedagem compartilhada completo com cobrança, e-mail, domínio, revenda e suporte a qualquer stack.
- Editar livremente arquivos críticos do sistema ou configurações Nginx sem validação e versionamento.
- Prometer rollback automático universal para ações que o próprio WordOps ou o sistema operacional não conseguem desfazer com segurança.

2. Contexto, problema e discovery

2.1 Fundamento técnico confirmado

WordOps é uma ferramenta de linha de comando para instalar e administrar uma stack LEMP otimizada e provisionar sites WordPress ou PHP. O projeto oferece operações de site, stacks, SSL com Let's Encrypt, múltiplos backends de cache e ferramentas de monitoramento. Existe um dashboard oficial voltado principalmente a métricas e atalhos; a proposta aqui é um produto operacional multi-servidor, com provisionamento e governança.

Capacidade WordOps relevante	Implicação no produto
Criar HTML, PHP, PHP+MySQL, proxy, alias e WordPress.	O wizard deve variar campos e validações conforme o tipo de site.
WordPress sem cache, FastCGI, Redis, WP Super Cache, WP-Rocket e Cache Enabler.	Cache é uma decisão explícita; compatibilidade deve ser detectada no servidor.
Alterar PHP, tipo/cache, HSTS, ngxblocker e SSL.	A tela de site precisa oferecer operações seguras e mostrar impacto.
Stacks instaláveis: Nginx, versões PHP, MariaDB, Redis, dashboard, Netdata, Fail2ban, ProFTPD, UFW etc.	A plataforma deve descobrir e administrar capacidades, não assumir uma instalação idêntica.
Listar, inspecionar, habilitar, desabilitar e excluir sites.	Inventário e lifecycle podem ser reconciliados com o estado real.
FTP users não têm um comando WordOps simples documentado.	O agente implementará uma operação própria e segura, preferencialmente FTPS/SFTP, com isolamento por site.

Regra de compatibilidade

Nunca codifique a lista de versões PHP ou stacks apenas no frontend. O agente consulta a versão do WordOps, sistema operacional, pacotes e opções suportadas; o control plane renderiza escolhas com base em capabilities versionadas.

2.2 Problemas observados

- Conhecimento operacional fica concentrado em quem domina WordOps, Linux, Nginx, DNS e certificados.
- Uma ação simples pode envolver várias verificações: DNS, pacote instalado, versão PHP, cache, certificado, permissões e resultado final.
- Comandos executados diretamente não geram necessariamente um histórico central acessível ao time.
- Múltiplos servidores produzem inventários fragmentados e dificultam saber onde cada site está e qual configuração utiliza.
- Credenciais e acessos de arquivos costumam ser criados manualmente, com risco de permissão ampla, senha reutilizada ou protocolo inseguro.
- Ações destrutivas ou upgrades podem competir entre si, falhar parcialmente ou ocorrer sem janela, backup e aprovação.

2.3 Hipóteses a validar com usuários

Hipótese	Como validar	Sinal de sucesso
O maior valor inicial está em criação e manutenção de sites, não em métricas avançadas.	Entrevistas e teste de protótipo com 5-8 operadores.	Mais de 70% priorizam os fluxos operacionais entre as três maiores dores.
Um wizard de 6-7 etapas é aceitável se reduzir erros.	Teste moderado com criação de site realista.	Taxa de conclusão $\geq 90\%$ sem ajuda; tempo mediano < 4 min antes da execução.
Equipes aceitam instalar agente local em troca de segurança e confiabilidade.	Entrevista técnica e piloto em 3 servidores.	Sem bloqueio de segurança; instalação < 10 min.
Acesso de arquivos deve ser chamado de "Acesso" e não apenas "FTP".	Teste de nomenclatura com operadores e desenvolvedores.	Usuários entendem SFTP/FTPS e preferem opção recomendada.
Aprovação em duas etapas é necessária apenas para manutenção e exclusão.	Mapeamento de governança por perfil.	Menos fricção nas rotinas e 100% de clareza nas ações críticas.

2.4 Premissas adotadas para esta versão

- O produto inicia com uma organização, múltiplos usuários, múltiplos servidores e múltiplos sites; banco e APIs já incluem organization_id.
- O servidor já possui WordOps ou pode ser preparado durante onboarding; sistemas recomendados seguem a matriz oficial detectada pelo agente.
- O DNS pode estar em qualquer provedor, mas a primeira integração profunda recomendada é Cloudflare; outros provedores entram por adapter.
- A interface é responsiva para consulta e ações simples, mas tarefas críticas e edição de configurações são desktop-first.
- Português do Brasil é o idioma inicial; arquitetura de internacionalização deve existir desde o início.
- Segredos são armazenados por referência e criptografia de envelope; nunca aparecem integralmente em logs, eventos ou analytics.

3. Usuários, personas e Jobs to Be Done

Persona	Responsabilidade	Tarefas principais	Necessidade central
Administrador de infraestrutura	Responsável por servidores, segurança e disponibilidade.	Conectar servidores, aprovar manutenção, resolver falhas, definir integrações e políticas.	Precisa de visibilidade, controle fino e evidência de cada mudança.
Operador web / atendimento técnico	Cria sites e executa alterações recorrentes.	Provisionar WordPress, alterar PHP/cache, emitir SSL, criar acesso e acompanhar jobs.	Quer rapidez com guardrails; não deve receber root.
Desenvolvedor	Trabalha em um ou mais sites.	Obter acesso isolado, consultar stack, logs do site e solicitar mudanças permitidas.	Quer autonomia sem acesso a outros clientes ou ao servidor inteiro.
Gestor / owner	Acompanha capacidade, riscos e produtividade.	Ver saúde, volume, falhas, auditoria e uso por equipe.	Quer resumo executivo, não detalhes de terminal.
Cliente convidado - futuro	Pode consultar ou administrar apenas seus próprios sites.	Visualizar status, backups e acessos delegados.	Precisa de experiência simples e marca branca.

3.1 Jobs to Be Done prioritários

- Quando eu receber um novo domínio, quero criar um site com a stack correta e SSL sem decorar flags, para publicar rápido e sem inconsistências.
- Quando um plugin exigir outra versão de PHP, quero saber quais versões existem no servidor, validar compatibilidade e mudar com backup e possibilidade de diagnóstico.
- Quando um desenvolvedor precisar enviar arquivos, quero criar um acesso restrito ao site e com expiração, sem entregar SSH/root.
- Quando um certificado estiver perto de expirar ou falhar, quero identificar a causa e renovar com o menor risco possível.
- Quando uma operação falhar, quero ver em que etapa ocorreu, o que foi alterado e qual ação segura devo tomar.
- Quando eu administrar vários servidores, quero localizar rapidamente um domínio e entender sua configuração, saúde e histórico.

3.2 Matriz de papéis

Papel	Escopo
Owner	Total, incluindo organização, billing futuro, chaves, exclusão e transferência.
Admin	Servidores, sites, integrações, equipe, manutenção e auditoria; não transfere ownership.
Operator	Cria e altera sites, SSL, backups e acessos dentro das políticas; sem stacks destrutivas.
Developer	Acesso somente aos sites atribuídos; logs, backups permitidos e gestão do próprio acesso.
Viewer	Somente leitura de dashboards, inventário, jobs e auditoria conforme escopo.
Client - futuro	Somente sites atribuídos e ações explicitamente liberadas.

Princípio de autorização

Permissão é a interseção de papel, organização, servidor/site atribuído e política da operação. Não basta esconder um botão: a API e o agente validam novamente.

4. Escopo, releases e prioridades

4.1 MVP - produto utilizável e seguro

- Autenticação, recuperação, MFA TOTP, organização e RBAC básico.
- Onboarding de servidor com agente, verificação de WordOps, capability discovery e inventário inicial.
- Dashboard, lista de servidores, saúde, serviços e alertas essenciais.
- Lista e busca global de sites; detalhe com configuração, SSL, PHP, cache, caminho e histórico.
- Wizard de criação: HTML, PHP, PHP+MySQL e WordPress; PHP disponível; caches principais; SSL de domínio; HSTS; credenciais WordPress; preview.
- Alterar versão PHP, cache/tipo WordPress, habilitar/desabilitar site, emitir/desativar SSL e HSTS.
- Criar, redefinir, expirar e remover usuário de acesso de arquivos com escopo de site; FTPS como primeira implementação segura.
- Jobs assíncronos com lock, streaming de logs, cancelamento quando tecnicamente seguro, retry e verificação final.
- Backup pré-operação de banco e configuração; backup manual de site; restauração guiada básica.
- Auditoria, notificações in-app/e-mail, integrações Cloudflare e storage S3-compatible.

4.2 V1 - operação profissional

- WordPress multisite, proxy, alias, subsite e vhost-only.
- Backups agendados incrementais com Restic, retenção e restauração granular.
- Manutenção de stacks, WordOps e pacotes com janela, aprovação e relatório.
- Logs de Nginx/PHP/WordPress com filtros e tail controlado.
- API pública, webhooks, service accounts e chaves com escopo.
- SSO OIDC/SAML, políticas por organização, aprovação em duas etapas e IP allowlist.
- SFTP chrooted opcional, rotação automática de credenciais e acesso temporário.
- Integrações DNS adicionais por adapter e certificados wildcard.

4.3 V2 / visão futura

- Clone/staging, migração entre servidores, templates de site e blueprints de plugins/temas.
- Recomendações de capacidade, detecção de anomalias e automações baseadas em políticas.
- White-label, portal de cliente, billing, planos, quotas e marketplace de integrações.
- Suporte a stacks adicionais por provider interface, sem misturar regras no núcleo WordOps.
- Fleet management avançado, rollout por grupos, canary e compliance reports.

4.4 Priorização MoSCoW

Categoria	Itens
Must	Agente seguro; auth/RBAC; servidores; inventário; criar site; PHP/cache/SSL; acesso por site; jobs/logs; backup mínimo; auditoria.
Should	Cloudflare; backup remoto; notificações; manutenção segura; logs operacionais; API/webhooks.
Could	Staging/clone; portal de cliente; white-label; analytics avançado; sugestões automáticas.
Won't now	Terminal web arbitrário; hospedagem de e-mail; domínio/registrar; cPanel completo; suporte genérico a qualquer distribuição.

5. Requisitos funcionais completos

Cada requisito usa prioridade P0 (bloqueante para MVP), P1 (importante para MVP/V1) ou P2 (evolução). Critério de aceite é resumido nesta seção e aprofundado nos fluxos críticos.

5.1 Conta, organização e equipe

ID	Requisito	Pri.	Aceite resumido
FR-AUTH-001	Cadastrar e autenticar usuário com e-mail verificado.	P0	Sessão segura; e-mail normalizado; rate limit; eventos de login auditados.
FR-AUTH-002	MFA TOTP com recovery codes.	P0	Owner/Admin podem exigir MFA; códigos exibidos uma vez e armazenados com hash.
FR-AUTH-003	Recuperação e troca de senha com revogação de sessões.	P0	Token único, curto e inutilizado após uso; opção de encerrar todas as sessões.
FR-ORG-001	Criar organização e convidar membros.	P0	Convite expira; papel definido; reenvio/revogação disponíveis.
FR-RBAC-001	Aplicar autorização por papel e escopo de servidor/site.	P0	API nega acesso mesmo por URL direta; testes de matriz cobrindo cada papel.
FR-AUD-001	Registrar eventos de segurança e mudanças.	P0	Ator, alvo, antes/depois redigido, IP, timestamp, job e correlação.

5.2 Onboarding e gestão de servidores

ID	Requisito	Pri.	Aceite resumido
FR-SRV-001	Adicionar servidor por token de bootstrap manual.	P0	Token expira em 15 min, uso único, checksum do instalador e confirmação visual do fingerprint.
FR-SRV-002	Opcionalmente bootstrap por SSH efêmero.	P1	Chave temporária removida após instalação; senha nunca persistida.
FR-SRV-003	Detectar OS, WordOps, versão, stacks, PHPs, serviços, recursos e IPs.	P0	Capabilities versionadas e atualizadas em heartbeat/inventory sync.
FR-SRV-004	Importar sites existentes sem recriá-los.	P0	Reconciliação usa lista/info e filesystem; conflitos aparecem para revisão.
FR-SRV-005	Exibir saúde de CPU, memória, disco, load e serviços.	P0	Status recente com timestamp; servidor offline destacado após janela configurada.
FR-SRV-006	Editar nome, tags, ambiente, timezone e janela de manutenção.	P1	Metadados não alteram hostname sem operação explícita.
FR-SRV-007	Remover servidor do painel sem apagar sites.	P0	Requer confirmação; revoga certificado do agente e preserva auditoria.

5.3 Dashboard e busca

ID	Requisito	Pri.	Aceite resumido
FR-DASH-001	Dashboard com total de servidores/sites e estados.	P0	Dados por organização; filtros por tag/ambiente; timestamp de atualização.
FR-DASH-002	Cards de alertas críticos, jobs falhos, disco e SSL.	P0	Cada card leva à lista filtrada e informa severidade/idade.

ID	Requisito	Pri.	Aceite resumido
FR-SEARCH-001	Busca global por domínio, servidor, IP e usuário de acesso.	P0	Resultado em menos de 500 ms P95 com até 10 mil sites no alvo de V1.
FR-DASH-003	Atividade recente e ações rápidas.	P1	Somente ações autorizadas aparecem; nenhuma ação destrutiva é executada em um clique.

5.4 Inventário e detalhe de site

ID	Requisito	Pri.	Aceite resumido
FR-SITE-001	Listar sites com domínio, servidor, tipo, PHP, cache, SSL e estado.	P0	Ordenação, filtros, paginação e estado reconciliado.
FR-SITE-002	Exibir detalhe técnico e caminhos sem revelar segredos.	P0	Mostra root, logs, banco mascarado, certificado, DNS e histórico.
FR-SITE-003	Habilitar e desabilitar vhost.	P0	Confirma impacto; job verifica Nginx e resposta após alteração.
FR-SITE-004	Mostrar configuração Nginx em leitura.	P1	Conteúdo sanitizado; download auditado; edição livre fora do MVP.
FR-SITE-005	Detectar drift entre banco do painel e servidor.	P1	Marca “desatualizado” e oferece reconciliar sem sobrescrever silenciosamente.

5.5 Criação de sites

ID	Requisito	Pri.	Aceite resumido
FR-CREATE-001	Wizard com seleção de servidor e validação de domínio.	P0	Valida sintaxe, duplicidade, IDN/punycode, DNS e espaço livre.
FR-CREATE-002	Criar HTML, PHP e PHP+MySQL.	P0	Comando é montado por adapter; resultado validado por site info e arquivos.
FR-CREATE-003	Criar WordPress com cache escolhido.	P0	Somente opções suportadas; admin e URL validados; credenciais tratadas como segredo.
FR-CREATE-004	Escolher versão PHP disponível.	P0	Lista vem das capabilities; opção pode instalar stack mediante permissão e confirmação.
FR-CREATE-005	Configurar SSL, HSTS e DNS challenge.	P0/P1	SSL comum no MVP; wildcard e providers adicionais em V1.
FR-CREATE-006	Exibir resumo e preview técnico antes de executar.	P0	Mostra impacto e flags, mas redige senhas/tokens.
FR-CREATE-007	Permitir salvar blueprint de configuração.	P2	Blueprint não armazena senha; pode ser aplicado a outro servidor compatível.

5.6 WordPress, PHP e cache

ID	Requisito	Pri.	Aceite resumido
FR-WP-001	Definir usuário, e-mail e idioma do WordPress.	P0	Senha gerada/atualizada por canal seguro; nunca em analytics ou logs.
FR-WP-002	Abrir wp-admin e copiar credenciais temporárias.	P0	Credencial revelada uma vez, com confirmação e auditoria.

ID	Requisito	Pri.	Aceite resumido
FR-PHP-001	Alterar PHP do site.	P0	Pré-check de versão instalada, backup, lock, update, reload e health check.
FR-CACHE-001	Trocar backend de cache WordPress.	P0	Matriz de transição validada; cache limpo; resposta e wp-admin verificados.
FR-WP-003	Executar limpeza de cache por site.	P1	Operação allowlisted; resultado e duração registrados.
FR-WP-004	Atualizar senha de admin via fluxo seguro.	P1	Usa WP-CLI prompt/stdin quando possível; segredo não aparece no comando exibido.

5.7 SSL, DNS e segurança do site

ID	Requisito	Pri.	Aceite resumido
FR-SSL-001	Emitir certificado Let's Encrypt para domínio/subdomínio.	P0	Pré-check DNS/portas; falha apresenta causa; data de validade armazenada.
FR-SSL-002	Ativar/desativar HSTS.	P0	Aviso forte antes de ativar; só com HTTPS válido; rollback disponível.
FR-SSL-003	Desativar SSL gerenciado.	P1	Confirmação de impacto; mantém registro do certificado anterior.
FR-SSL-004	Wildcard via DNS API.	P1	Credencial de provider é segredo; suporte depende de capability do acme.sh.
FR-DNS-001	Integrar Cloudflare e testar credencial.	P1	Escopo mínimo de token; zones listadas; segredo nunca retornado pela API.
FR-SEC-001	Ativar/desativar ngxblocker quando suportado.	P1	Capability detectada; alteração verificada e auditada.

5.8 Usuários de acesso de arquivos

ID	Requisito	Pri.	Aceite resumido
FR-ACC-001	Criar usuário FTPS restrito ao diretório do site.	P0	Sem shell, home no site, grupo/ACL correto, senha forte e nenhum acesso a outros sites.
FR-ACC-002	Definir expiração, status e descrição.	P0	Conta desabilita automaticamente na expiração; job auditado.
FR-ACC-003	Redefinir senha e revogar sessões quando aplicável.	P0	Nova senha revelada uma vez; antiga deixa de funcionar.
FR-ACC-004	Remover acesso sem remover arquivos.	P0	Usuário Linux removido/disabled; ownership não é quebrado.
FR-ACC-005	SFTP chrooted como opção.	P1	Somente quando servidor passa preflight; documentação de compatibilidade.
FR-ACC-006	Proibir FTP sem TLS.	P0	UI não oferece protocolo inseguro; agente rejeita operação.

5.9 Banco de dados

ID	Requisito	Pri.	Aceite resumido
FR-DB-001	Exibir banco e usuário mascarados, com copiar/revelar controlado.	P1	Revelação exige reautenticação e gera auditoria.

ID	Requisito	Pri.	Aceite resumido
FR-DB-002	Gerar dump manual e download temporário.	P1	Arquivo criptografado/expirável; limite e progresso visíveis.
FR-DB-003	Restaurar dump com backup prévio.	P1	Validação de formato/tamanho; confirmação; health check pós-restore.
FR-DB-004	Links seguros para Adminer/phpMyAdmin quando instalados.	P1	Disponibilidade detectada; sem armazenar senha em URL.

5.10 Backups e restauração

ID	Requisito	Pri.	Aceite resumido
FR-BKP-001	Criar backup manual de arquivos, banco e configuração.	P0	Progresso, checksum, tamanho, duração e destino registrados.
FR-BKP-002	Executar backup automático antes de operações de risco.	P0	Política por operação; job principal não inicia se backup obrigatório falhar.
FR-BKP-003	Restaurar backup completo.	P0/P1	Modo manutenção/disable opcional, rollback do restore em caso de verificação falha.
FR-BKP-004	Agendar backups e retenção.	P1	Timezone explícito; política grandfather-father-son opcional; alertas de falha.
FR-BKP-005	Storage S3-compatible com Restic.	P1	Criptografia client-side; segredo por referência; teste de escrita/leitura.

5.11 Jobs, logs e erros

ID	Requisito	Pri.	Aceite resumido
FR-JOB-001	Toda mutação relevante gera job.	P0	Job tem estado, etapas, ator, alvo, idempotency key e correlation id.
FR-JOB-002	Streaming de logs redigidos.	P0	SSE/WebSocket; tokens/senhas/headers sensíveis removidos antes de persistir.
FR-JOB-003	Lock por servidor/site e classes de operação.	P0	Não há PHP update concorrente com backup/restore/exclusão do mesmo site.
FR-JOB-004	Retry somente quando seguro.	P0	Política por erro/operação; não repete criação destrutivamente sem reconciliação.
FR-JOB-005	Cancelar apenas etapas canceláveis.	P1	UI explica quando cancelamento não é seguro e oferece acompanhar.
FR-JOB-006	Diagnóstico e ações sugeridas.	P1	Erro mapeado para causa provável, evidência e próxima ação, sem mascarar log bruto redigido.

5.12 Stacks e manutenção

ID	Requisito	Pri.	Aceite resumido
FR-STK-001	Visualizar stacks instaladas e versões.	P0	Estado coletado pelo agente; diferencia disponível, instalada e em execução.
FR-STK-002	Instalar stack necessária com aprovação.	P1	Preflight de disco/OS/repositório; plano e impacto exibidos.

ID	Requisito	Pri.	Aceite resumido
FR-STK-003	Reiniciar/recarregar serviço.	P1	Somente serviços allowlisted; health check antes/depois.
FR-MNT-001	Atualizar WordOps e stacks em janela de manutenção.	P1	Backup/config snapshot, approval, relatório e rollback documentado.
FR-MNT-002	Bloquear purge destrutivo no MVP.	P0	Nenhuma rota/command permite stack purge; recurso futuro exige controle extraordinário.

5.13 Notificações, integrações e API

ID	Requisito	Pri.	Aceite resumido
FR-NOT-001	Notificar falha de job, servidor offline, disco crítico, backup e SSL.	P0/P1	In-app e e-mail; regras por severidade e quiet hours.
FR-INT-001	Integração Cloudflare.	P1	OAuth/token de escopo mínimo; teste; rotação; desconexão.
FR-INT-002	Integração S3-compatible.	P1	Endpoint, bucket, region e credencial testados; secrets masked.
FR-API-001	API pública versionada e idempotente.	P1	OpenAPI; scopes; rate limit; exemplos; erros padronizados.
FR-WHK-001	Webhooks assinados.	P1	HMAC, retry com backoff, replay protection e logs de entrega.

6. Fluxos críticos e critérios de aceite

6.1 Onboarding de servidor

1. Usuário Admin escolhe "Adicionar servidor", informa nome, ambiente e tags.
2. Painel gera token de bootstrap de uso único e comando com URL, token e checksum; alternativa por SSH efêmero pode ser oferecida.
3. Instalador valida OS, arquitetura, privilégios, conectividade HTTPS, relógio e dependências; instala agente e unidade systemd.
4. Agente gera chave local, conclui registro por mTLS e mostra fingerprint no painel e no terminal para conferência.
5. Agent executa discovery: WordOps, versão, PHPs, stacks, serviços, recursos, sites e endpoints locais.
6. Painel apresenta resumo de importação, conflitos e itens não gerenciados; usuário confirma.
7. Servidor entra como "Saudável", "Atenção" ou "Incompatível", com próximos passos claros.

Aceite crítico

Nenhuma senha SSH fica armazenada. Um token expirado ou reutilizado falha. A remoção do servidor revoga o certificado do agente. Um agente de outra organização não consegue registrar ou enviar dados.

6.2 Wizard de criação de site

Etapa	Campos / decisões	Validações
1. Destino	Servidor, domínio, ambiente, tags.	Servidor online; domínio válido e único; IDN convertido; espaço e load aceitáveis.
2. Tipo	HTML, PHP, PHP+MySQL, WordPress; V1: proxy/alias/multisite.	Campos condicionais; opções compatíveis com capabilities.
3. Runtime	Versão PHP, cache, Redis, ngxblocker.	PHP instalada ou instalação aprovada; combinações inválidas desabilitadas.
4. Aplicação	Usuário/e-mail/idioma WordPress; vhost-only; blueprint.	E-mail válido; username seguro; senha gerada ou definida sem log.
5. Domínio e SSL	Let's Encrypt, HSTS, wildcard/DNS provider.	A/AAAA/CNAME, porta 80/443, token DNS, aviso HSTS.
6. Acesso e backup	Criar acesso FTPS, expiração, backup inicial.	Username único no servidor; política de senha; storage disponível.
7. Revisão	Resumo humano, preview técnico, impacto e estimativa.	Segredos redigidos; confirmação explícita; idempotency key.

6.3 Sequência de execução da criação

1. Criar job e adquirir lock exclusivo de servidor para provisionamento.
2. Reexecutar preflight no agente imediatamente antes da mudança.
3. Instalar dependências ausentes somente quando autorizado e registrá-las como subjobs.
4. Executar adapter WordOps com argv tipado, sem shell interpolada.
5. Capturar stdout/stderr, redigir segredos e emitir eventos de progresso.
6. Executar verificação: wo site info, arquivos, Nginx config test, serviços e HTTP/HTTPS.
7. Persistir inventário final, certificado, stack, caminhos e credenciais por referência.
8. Liberar lock, enviar notificação e mostrar resumo com próximos passos.

```
# Exemplo de preview técnico (senha omitida)
wo site create exemplo.com --wpredis --php84 --letsencrypt --hsts \
  --user=admin --email=admin@exemplo.com

# O agente executa por lista de argumentos, não por string de shell.
# Senhas personalizadas são definidas depois por fluxo seguro, preferencialmente via stdin/prompt.
```

6.4 Alteração de PHP

1. Selecionar nova versão entre as capabilities do servidor; versões não instaladas aparecem com custo/impacto de instalação.
2. Executar health baseline, backup obrigatório de configuração e banco; opcional de arquivos conforme política.
3. Bloquear site, validar espaço e versão WordOps, executar update tipado e recarregar serviços.
4. Validar Nginx, PHP-FPM, HTTP/HTTPS e wp-admin; comparar baseline.
5. Se falhar, apresentar diagnóstico e oferecer retorno à versão anterior como novo job, nunca rollback silencioso.

Critério de segurança

O botão "Voltar para a versão anterior" inicia uma operação nova, auditável e sujeita a preflight. O painel não deve afirmar que toda incompatibilidade de plugin será automaticamente revertida.

6.5 Criação de acesso de arquivos

1. Usuário escolhe site, protocolo permitido, username, descrição e expiração.
2. Agente verifica ProFTPd/FTPS ou suporte SFTP, username global, path do site e política de permissões.
3. Conta é criada sem shell, restrita ao site e ao grupo/ACL adequado; FTP sem TLS é rejeitado.
4. Senha aleatória forte é gerada e exibida uma vez; hash fica no sistema operacional, não no banco do painel.
5. Teste automatizado confirma login e impossibilidade de navegar para outro site, quando viável em ambiente de teste seguro.
6. Revogação desabilita/remove a conta sem apagar arquivos e preserva auditoria.

6.6 Exclusão de site

- Oferecer primeiro "Desabilitar site" como ação reversível.
- Exclusão permanente exige papel Admin/Owner, reautenticação, digitação do domínio e seleção do escopo: arquivos, banco ou ambos.
- Backup obrigatório por padrão; exceção somente por política e confirmação extraordinária registrada.
- Preview lista caminhos e banco que serão removidos; aliases/subsites/dependências precisam ser detectados.
- Após execução, reconciliar filesystem, banco, vhost, certificados e inventário; manter tombstone e auditoria sem segredo.

7. Arquitetura de informação e mapa de telas

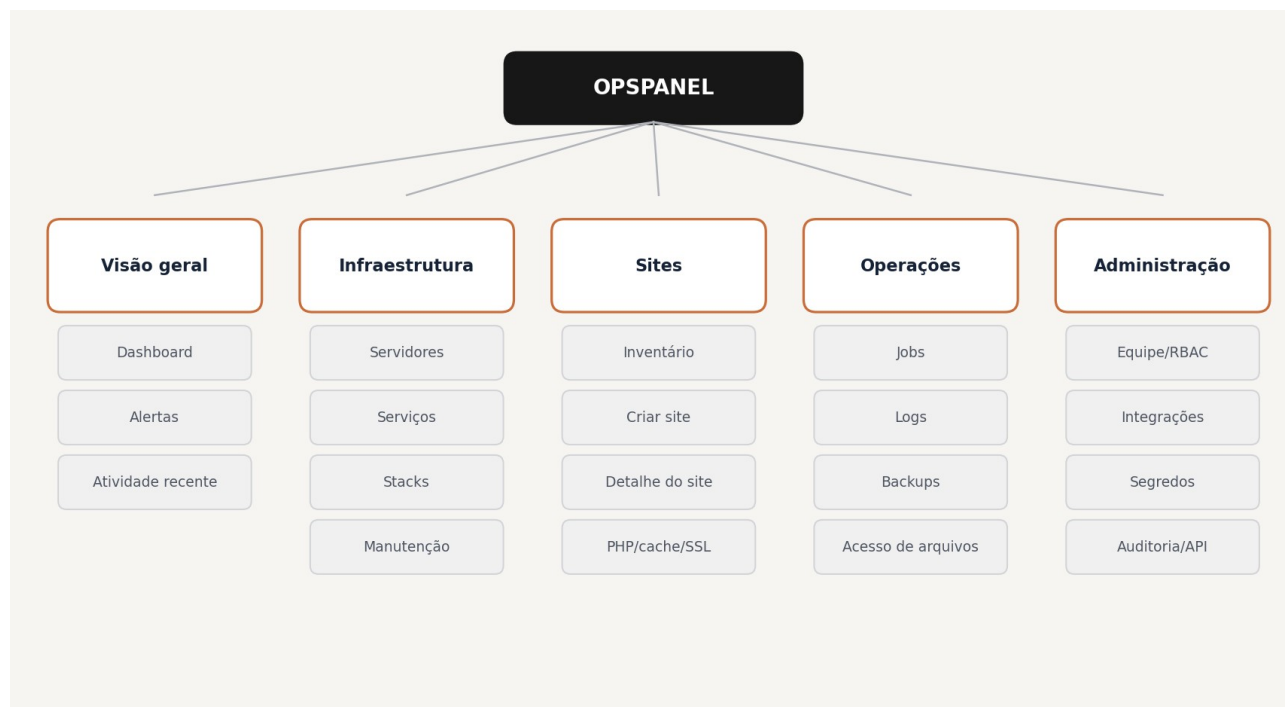


Figura 1 - Arquitetura de informação proposta para navegação principal.

7.1 Navegação principal

Item	Conteúdo	Ação primária
Visão geral	Saúde, alertas, inventário, jobs e atividade.	Criar site / adicionar servidor.
Servidores	Lista, tags, status, recursos, capabilities e manutenção.	Adicionar servidor.
Sites	Busca global, filtros, configurações e estados.	Criar site.
Operações	Jobs, logs, backups e acessos.	Reexecutar/diagnosticar conforme permissão.
Administração	Equipe, RBAC, integrações, segredos, API e auditoria.	Convidar membro / conectar integração.

7.2 Inventário de telas

ID	Tela	Objetivo
S01	Login / MFA	Autenticação e recuperação.
S02	Onboarding inicial	Criar organização e primeiro servidor.
S03	Dashboard	Resumo operacional e ações rápidas.
S04	Servidores	Lista, filtros, tags e estado.
S05	Adicionar servidor	Bootstrap e progresso de conexão.
S06	Detalhe do servidor	Saúde, serviços, stacks, sites, jobs e manutenção.
S07	Sites	Inventário e busca global.
S08	Criar site	Wizard completo.

ID	Tela	Objetivo
S09	Detalhe do site	Overview, runtime, SSL, banco, acesso, backups, logs e atividade.
S10	Alterar PHP/cache	Drawer/modal com preflight e impacto.
S11	SSL e DNS	Certificado, validade, provider e renovação.
S12	Acesso de arquivos	Lista, criação, expiração e revogação.
S13	Backups	Políticas, execuções e restore.
S14	Jobs	Lista e detalhe com timeline e logs.
S15	Logs	Nginx/PHP/WordPress por escopo.
S16	Manutenção	Plano, janela, aprovação e relatório.
S17	Equipe e papéis	Membros, convites e atribuições.
S18	Integrações e segredos	Cloudflare, S3, SMTP e webhooks.
S19	Auditoria	Eventos, filtros, exportação.
S20	API	Chaves, scopes, docs e entregas de webhook.

7.3 Estrutura do detalhe do site

- Overview: estado, URL, servidor, stack, PHP, cache, SSL, último backup e última operação.
- Runtime: PHP, cache, Nginx, Redis e ações permitidas.
- Domínio e SSL: DNS observado, certificado, validade, HSTS e integração.
- WordPress: admin URL, versão, idioma, usuário administrativo e limpeza de cache.
- Banco: metadados mascarados, dump/restore e links administrativos.
- Acesso: FTPS/SFTP, usuários, expiração, rotação e instruções de conexão.
- Backups: pontos de restauração, destino, retenção e restore.
- Logs e atividade: logs operacionais, jobs e auditoria relacionada.

8. Direção UX/UI e design system glassmorphism

A referência enviada combina fundo em degradê quente/frio, grande superfície translúcida, bordas claras, cantos amplos, navegação lateral discreta, cards brancos e um card escuro de alto contraste. A plataforma deve adotar essa linguagem com mais rigor de acessibilidade, densidade adequada a operações técnicas e hierarquia visual clara.

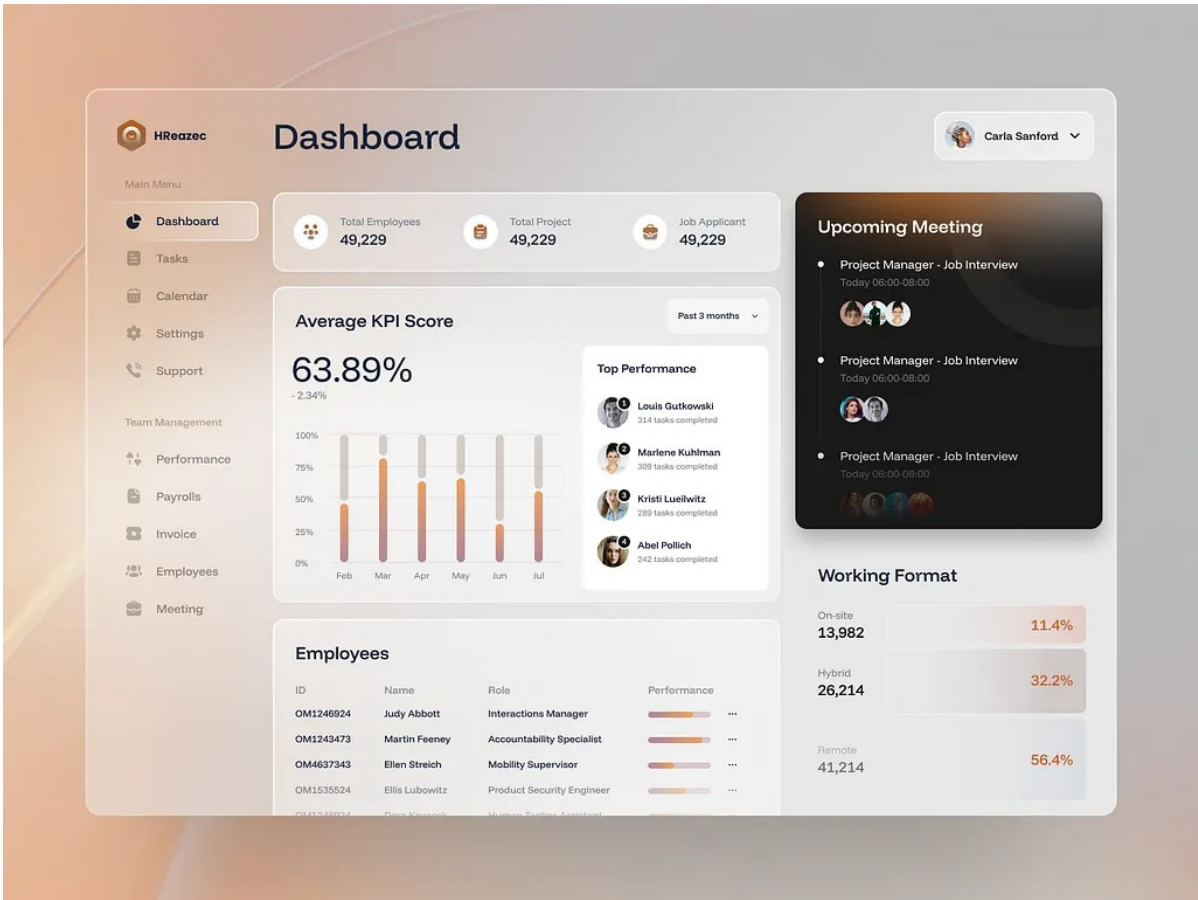


Figura 2 - Referência visual fornecida: painel claro com glassmorphism, tons pêssego/cinza e card operacional escuro.

8.1 Princípios visuais

- **Luxo técnico e silencioso.** Poucos efeitos, transparência controlada, sombras suaves e tipografia precisa; sem aparência gamer ou excesso de neon.
- **Clareza antes do efeito.** Glassmorphism nunca pode prejudicar contraste, leitura de tabela, foco ou estados de erro.
- **Dados em camadas.** Resumo em cards; detalhes em tabelas/drawers; logs em superfície escura monoespçada.
- **Ações destrutivas visíveis, não dominantes.** Vermelho reservado a risco real; confirmação por conteúdo, não apenas por cor.
- **Consistência operacional.** Toda ação segue padrão: preflight > revisão > execução > verificação > resultado.

8.2 Tokens recomendados

Token	Valor	Uso
Background warm	#EAC0A7	Início do degradê e realces pêssego.
Background cool	#C6C8CB	Fim do degradê e áreas neutras.
Glass surface	rgba(255,255,255,.62)	Painel principal com backdrop blur 24-32px.
Glass border	rgba(255,255,255,.75)	Borda 1px; elevar contraste em dark mode.
Text primary	#162237	Títulos e dados principais.
Text secondary	#6C7280	Metadados; validar contraste mínimo.
Accent	#C96D3A	Ações primárias, seleção e progresso.

Token	Valor	Uso
Dark card	#171717	Jobs, alertas e logs de alta atenção.
Success	#287A5A	Saudável/concluído.
Warning	#A77422	Atenção/pendente.
Danger	#B54848	Falha/destrutivo.
Radius	20 / 14 / 10 px	Shell / cards / controles.
Spacing	4, 8, 12, 16, 24, 32 px	Escala base de 4 px.
Typography	Geist ou Inter	Display 600/700; body 400/500; mono para logs.

8.3 Layout desktop

- Shell máximo de 1440-1600 px, margem externa 24-40 px, background fixo e painel glass principal.
- Sidebar 224-248 px recolhível; logo, seletor de organização, navegação e status do agente/conta.
- Header com breadcrumb, busca global, command palette, notificações e usuário.
- Grid de 12 colunas; cards de resumo em 3-4 colunas; conteúdo principal em 8/4 ou 9/3.
- Tabelas dentro de superfícies opacas 88-96% para preservar legibilidade; cabeçalho sticky.
- Drawer direito de 420-560 px para operações; modal central apenas para decisões curtas.

8.4 Responsividade

Breakpoint	Comportamento
>= 1280 px	Sidebar aberta; grid completo; detalhe com duas colunas.
1024-1279 px	Sidebar compacta; cards reorganizados; tabelas com colunas secundárias ocultáveis.
768-1023 px	Navegação em drawer; detalhe em uma coluna; ações críticas continuam acessíveis.
< 768 px	Consulta, aprovação e acompanhamento; wizard simplificado. Logs/tabelas usam cards e scroll horizontal explícito.

8.5 Componentes essenciais

Componente	Especificação
Status chip	Ícone + texto + cor; nunca apenas cor. Estados: saudável, atenção, crítico, offline, executando, pendente.
Metric card	Título curto, valor, delta/contexto e link; no máximo uma ação.
Resource bar	Percentual, valor absoluto, limite e threshold; tooltip acessível.
Data table	Busca, filtros salvos, seleção, densidade, colunas, paginação e empty/error states.
Operation drawer	Resumo, preflight, impacto, opções, preview, confirmação e CTA.
Job timeline	Etapas, duração, estado, logs e ações; scroll preservado em streaming.
Secret field	Mascarado; revelar exige ação; copiar expira; nunca pré-carregado em HTML quando não necessário.
Command preview	Monospace, read-only, flags segmentadas e segredos redigidos; explicação humana acima.
Danger confirm	Consequência, alvo, backup, typed confirmation e reautenticação conforme risco.
Toast/notification	Mensagem curta com link; falhas persistentes também aparecem no centro de notificações.

8.6 Estados e microcopy

Situação	Mensagem recomendada
Servidor offline	"Não recebemos heartbeat há 4 minutos. Nenhuma nova operação será iniciada até o agente voltar."
DNS incorreto	"O domínio aponta para 203.0.113.10, mas este servidor usa 203.0.113.25. Corrija o DNS antes de emitir o certificado."
PHP ausente	"PHP 8.4 não está instalada neste servidor. Instalar pode reiniciar serviços e afetar outros sites."
Job falhou	"A alteração não foi confirmada. O site continua respondendo com a configuração anterior observada. Revise o diagnóstico."
Senha criada	"Esta senha será exibida uma única vez. Guarde-a agora em um gerenciador de senhas."
Exclusão	"Esta ação remove arquivos e banco de dados do domínio. O backup selecionado será criado antes da exclusão."

8.7 Acessibilidade

- WCAG 2.2 AA como meta; contraste mínimo 4,5:1 para texto normal e 3:1 para texto grande/componentes.
- Todos os fluxos operáveis por teclado, com foco visível e ordem previsível.
- Prefers-reduced-motion reduz blur animado, transições e skeletons complexos.
- Leitores de tela recebem estado de jobs por aria-live sem anunciar cada linha de log.
- Gráficos sempre têm resumo textual e tabela/tooltip acessível.
- Tamanho de alvo mínimo 44x44 px em touch e mensagens que não dependem de cor.

9. Arquitetura técnica recomendada

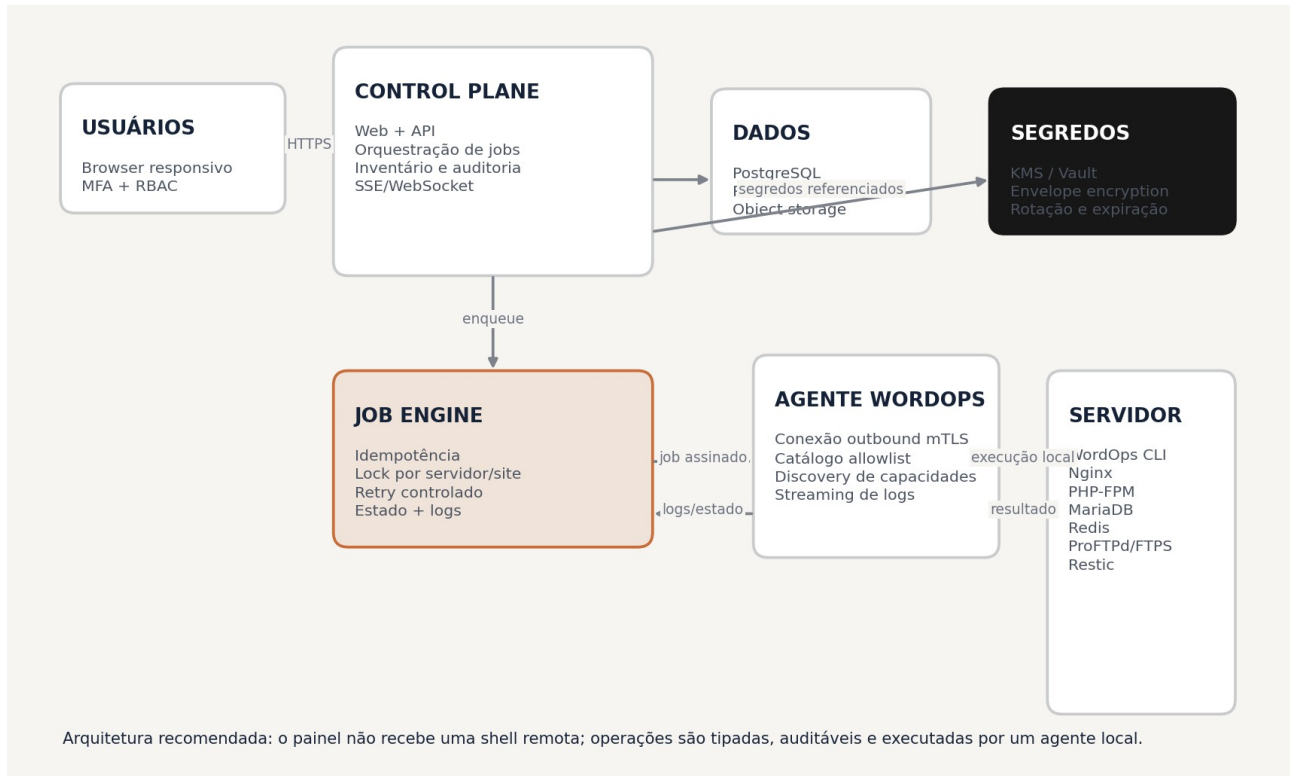


Figura 3 - Control plane, job engine, agente local e componentes de dados/segredos.

9.1 Stack sugerida

Camada	Tecnologia recomendada	Justificativa
Web	Next.js + React + TypeScript; Tailwind; Radix/shadcn; TanStack Query/Table.	SSR/app shell, ecossistema forte, acessibilidade e velocidade de produto.
API/control plane	NestJS com Fastify ou framework TypeScript equivalente.	Módulos, OpenAPI, guards, workers e contratos compartilhados.
Agente	Go, binário estático, systemd, auto-update assinado.	Baixo consumo, concorrência, distribuição simples e boa integração com processos.
Banco	PostgreSQL 16+ com migrations.	Dados relacionais, JSONB para capabilities, locks e auditoria.
Fila/cache	Redis + BullMQ ou fila equivalente.	Jobs, rate limit, eventos e coordenação; estado final permanece no PostgreSQL.
Objetos	S3-compatible / MinIO.	Backups, exports e artefatos temporários.
Segredos	KMS/Vault ou envelope encryption com chave mestra externa.	Separação entre dados e material criptográfico; rotação.
Realtime	SSE para logs/progresso; WebSocket somente quando necessário.	SSE é simples, reconectável e suficiente para streaming unidirecional.
Observabilidade	OpenTelemetry + Prometheus/Grafana + Loki/Tempo ou serviço gerenciado.	Métricas, logs, traces e correlação ponta a ponta.

Alternativa enxuta

Para um MVP interno, web e API podem compartilhar um monorepo e deployment. O agente deve continuar separado. Evite iniciar com Kubernetes se Docker Compose, backups e observabilidade atendem a escala inicial.

9.2 Princípios de arquitetura

- Control plane não é fonte única da verdade do servidor; estado desejado e observado são separados e reconciliados.
- Operações são commands tipados com schema, versão e policy; nunca strings de shell recebidas do cliente.
- Agente inicia conexão outbound 443/mTLS; não depende de porta inbound pública.
- Cada job é idempotente quando possível e possui lock de concorrência explícito.
- Segredos são referenciados; o worker recebe apenas o necessário e por tempo limitado.
- O resultado de um comando não basta: toda mutação termina em verificação independente.
- Capabilities são versionadas para suportar diferenças entre WordOps, OS e pacotes.
- Falha do control plane não derruba sites; falha do agente apenas impede novas operações e atualizações de telemetria.

9.3 Topologia de deployment

- Web/API atrás de reverse proxy com TLS, WAF/rate limit e sessões seguras.
- Workers separados por fila: provisioning, backups, maintenance, notifications e inventory.
- PostgreSQL com backup point-in-time; Redis não é repositório definitivo de jobs.
- Object storage com lifecycle e criptografia; downloads por URL assinada curta.
- Agentes em canais stable/beta; rollout gradual e rollback para versão anterior assinada.

10. Modelo de domínio e dados

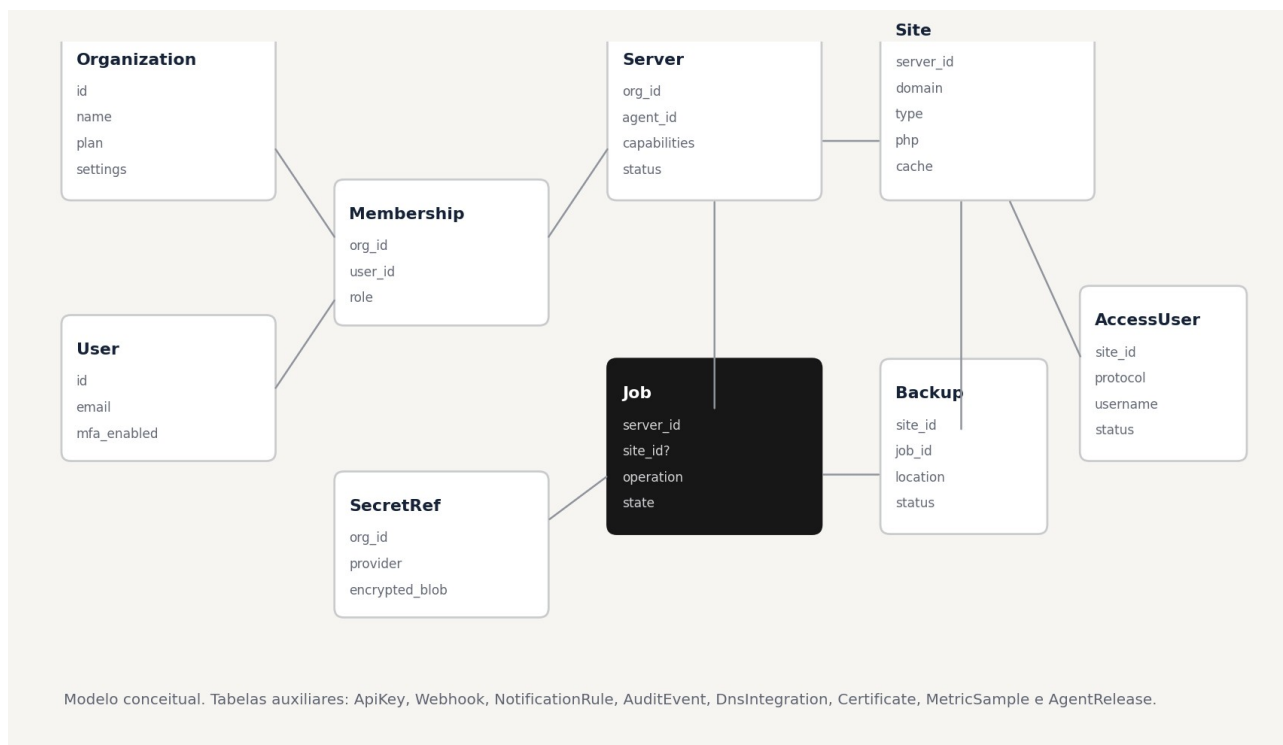


Figura 4 - Modelo de domínio conceitual; não substitui o diagrama físico e as migrations.

10.1 Entidades centrais

Entidade	Responsabilidade
Organization	Tenant, políticas, idioma, limites e configurações.
User	Identidade, MFA, status e preferências.
Membership	Relação usuário-organização, papel e escopos.
Server	Identidade, agente, OS, IPs, capabilities, estado observado e tags.
Agent	Certificado, versão, heartbeat, canal e fingerprint.
Site	Domínio, tipo, PHP, cache, SSL, estado desejado/observado e paths.
AccessUser	Usuário de arquivos, protocolo, expiração, status e site.
Job	Operação, payload validado, estado, locks, ator, tempos e diagnóstico.
JobStep	Etapa, tentativa, saída redigida, resultado e duração.
Backup	Escopo, destino, checksum, retenção, status e job.
Certificate	Domínios, emissor, validade, método e status.
SecretRef	Referência criptografada; metadados sem conteúdo em claro.
AuditEvent	Evento imutável de segurança e mudança.
Integration	Provider, estado, capabilities e secret refs.
NotificationRule	Eventos, severidades, canais e janela silenciosa.

10.2 Estados recomendados

Objeto	Estados
Server	pending, connecting, healthy, warning, critical, offline, incompatible, revoked.
Site	unknown, provisioning, active, disabled, warning, failed, deleting, deleted.
Job	requested, validating, queued, waiting_lock, running, verifying, succeeded, failed, cancel_requested, cancelled.
Backup	queued, running, verifying, available, failed, expired, deleting, deleted.
AccessUser	pending, active, expiring, expired, disabled, deleting, deleted, error.
Certificate	none, pending, valid, expiring, expired, renewal_failed, revoked.

10.3 Regras de integridade

- Domínio é único por organização para site ativo, salvo representação explícita de alias/subsite.
- Um server pertence a uma organização e um agent ativo pertence a um único server.
- Jobs destrutivos exigem target version ou snapshot de estado para evitar operar sobre objeto alterado.
- AuditEvent é append-only; correções geram novo evento, não edição do anterior.
- SecretRef nunca é serializado em responses comuns; endpoints de uso de segredo não retornam plaintext.
- AccessUser username precisa ser único no servidor, não apenas no site.
- Backup não é marcado available até checksum e teste de leitura concluírem.

11. API, agente e orquestração de jobs

11.1 Convenções da API

- Base `/api/v1`; JSON; IDs UUIDv7; timestamps ISO 8601 UTC; idioma em mensagens de UI, códigos de erro estáveis na API.
- Idempotency-Key obrigatório em POSTs de mutação operacional.
- Paginação cursor-based em listas grandes; filtros explícitos e ordenação permitida por whitelist.
- Erros no formato Problem Details com code, title, detail, correlation_id e field_errors.
- OpenAPI gerada no build, SDK TypeScript e exemplos cURL sem segredos reais.
- Rate limit por usuário, organização, API key e operação sensível.

11.2 Endpoints principais

Método	Endpoint	Uso
POST	/servers/bootstrap-tokens	Criar token de onboarding.
GET	/servers	Listar servidores.
GET	/servers/{id}	Detalhe e capabilities.
POST	/servers/{id}/reconcile	Reconciliar inventário.
POST	/servers/{id}/service-actions	Start/stop/reload/restart allowlisted.
GET	/sites	Listar/buscar sites.
POST	/sites	Solicitar criação de site.
GET	/sites/{id}	Detalhe do site.
POST	/sites/{id}/operations/php	Alterar PHP.
POST	/sites/{id}/operations/cache	Alterar cache/tipo.
POST	/sites/{id}/operations/ssl	Emitir/alterar SSL.
POST	/sites/{id}/operations/enable	Habilitar site.
POST	/sites/{id}/operations/disable	Desabilitar site.
DELETE	/sites/{id}	Solicitar exclusão.
GET/POST	/sites/{id}/access-users	Listar/criar acesso.
POST	/access-users/{id}/rotate	Redefinir senha.
DELETE	/access-users/{id}	Revogar/remover.
GET/POST	/sites/{id}/backups	Listar/criar backup.
POST	/backups/{id}/restore	Restaurar.
GET	/jobs	Listar jobs.
GET	/jobs/{id}	Detalhe.
GET	/jobs/{id}/events	SSE de progresso/logs.
POST	/jobs/{id}/retry	Retry seguro.
POST	/jobs/{id}/cancel	Solicitar cancelamento.
GET	/audit-events	Consulta de auditoria.
POST	/integrations/cloudflare	Conectar/testar.
POST	/api-keys	Criar chave com scopes.
POST	/webhooks	Cadastrar endpoint.

11.3 Contrato de operação

```
{
  "operation": "site.create",
  "schema_version": 1,
  "organization_id": "org...",
  "server_id": "srv...",
  "idempotency_key": "...",
  "requested_by": "usr...",
  "input": {
    "domain": "exemplo.com",
    "site_type": "wordpress",
    "cache": "redis",
    "php_version": "8.4",
    "ssl": {"mode": "letsencrypt", "hsts": true},
    "wordpress": {"admin_user": "admin", "admin_email": "admin@exemplo.com"},
    "secret_refs": {"wp_admin_password": "sec..."}
  },
  "expected_state_version": 7
}
```

11.4 Catálogo allowlist do agente

Operation key	Adapter local	Verificação
server.inventory	wo info / package/service probes	Capabilities assinadas e estado observado.
site.list	wo site list + site info	Domínios, tipo, PHP, cache e paths.
site.create	wo site create + flags validadas	site info, config test, HTTP/HTTPS.
site.update.php	wo site update <domain> --phpXX	PHP-FPM, Nginx e resposta.
site.update.cache	wo site update <domain> --wp*	Cache/backend, plugins e resposta.
site.ssl	wo site update/create --letsencrypt...	Certificado, validade e HTTPS.
site.enable/disable	wo site enable/disable	Vhost e resposta esperada.
site.delete	wo site delete com escopo	Ausência de files/db/vhost conforme pedido.
access.create	provisionamento local tipado	Usuário, home, shell, grupo/ACL e isolamento.
backup.create	mariadb-dump + restic/tar	Checksum, teste de leitura e catálogo.
service.action	systemctl allowlisted / wo stack action	Estado final e health check.

11.5 Segurança da execução

- Execução com subprocess argv; nunca `sh -c` com dados externos.
- Validação duplicada no control plane e no agente; schemas assinados e versionados.
- Domínios, usernames, paths, flags e provider IDs passam por allowlist/regex estrita.
- Paths são resolvidos e comparados ao root esperado para impedir traversal e symlink escape.
- Logs são redigidos no agente antes do transporte e novamente no control plane antes da persistência.
- Agente rejeita job expirado, replay, tenant incorreto, assinatura inválida ou versão de schema desconhecida.
- Operações root são limitadas ao catálogo; nenhuma API recebe comando livre.

11.6 Ciclo de vida de job



Figura 5 - Estados principais de uma operação.

Regra	Implementação
Lock	Chave por servidor e recurso; classes compartilhadas/exclusivas. TTL renovado por heartbeat do worker.
Idempotência	Mesma chave e mesmo payload retornam o job anterior; payload diferente gera conflito.
Retry	Backoff exponencial com jitter; somente erros classificados como transitórios e operação segura.
Timeout	Por etapa e por job; timeout não implica rollback automático.
Verificação	Probe independente do comando; resultado observado persistido.
Diagnóstico	Parser por adapter + evidências; código estável para UI e suporte.
Logs	Chunks com sequence number; SSE retoma por Last-Event-ID.

12. Segurança, privacidade e LGPD

12.1 Threat model resumido

Ameaça	Controle principal
Comprometimento de conta	MFA, sessões curtas/rotativas, rate limit, alertas e reautenticação.
Escalada por comando injetado	Operações tipadas, argv, allowlist, validação no agente e sem shell arbitrária.
Agente falso ou hijacked	mTLS, bootstrap de uso único, fingerprint, rotação e revogação.
Vazamento de segredo	KMS/envelope encryption, referências, redaction, acesso mínimo e reveal auditado.
Acesso cruzado entre tenants/sites	organization_id em toda autorização; RLS opcional; testes de isolamento; escopo no agente.
Exclusão acidental	RBAC, reauth, typed confirmation, backup e approval conforme política.
Supply chain	Build reproduzível, SBOM, assinatura de agente/instalador, pinning e verificação de checksum.
Replay de job	Nonce/idempotency, expiração, assinatura e sequence/correlation.
Backup comprometido	Criptografia client-side, checksum, imutabilidade opcional e teste de restore.

12.2 Controles obrigatórios

- TLS 1.2+; HSTS no control plane; cookies Secure, HttpOnly, SameSite; CSRF quando aplicável.
- Argon2id para senhas; TOTP secrets criptografados; recovery codes com hash.
- RBAC e object-level authorization em todas as rotas; deny by default.
- Criptografia at rest do banco/storage e envelope encryption de segredos sensíveis.
- Rotação de chaves, certificados de agentes e API keys; revogação imediata.
- Audit log imutável, exportável e com retenção definida; horário em UTC.
- Rate limits e proteção contra brute force; CAPTCHA apenas se necessário.
- SAST, dependency scanning, secret scanning, container scan e pentest antes de lançamento público.
- Backups do control plane e teste periódico de restauração.

12.3 Tratamento de segredos

Segredo	Armazenamento / uso
Senha WordPress	Gerada ou recebida em canal protegido; armazenada opcionalmente como secret ref; revelação única ou reauth.
Senha FTPS/SFTP	Hash permanece no servidor; plaintext exibido uma vez; painel pode não armazenar após criação.
Cloudflare token	Envelope encryption; escopo mínimo; entregue ao agente apenas para operação/renovação necessária.
S3 access key	Envelope encryption ou workload identity; nunca em logs, URLs ou eventos.
SSH bootstrap	Chave/token temporário; removido/revogado após instalação; não persistir senha.
Agent private key	Gerada e armazenada localmente com permissão 0600; nunca exportada ao control plane.

12.4 LGPD e privacidade

- Minimização: e-mail, nome, IP, logs de atividade e metadados estritamente necessários.
- Base legal e papéis de controlador/operador definidos conforme modelo SaaS ou self-hosted.
- Política de retenção para audit logs, jobs, métricas e backups; exclusão/anonymization quando aplicável.
- Exportação de dados de usuário e gestão de consentimentos somente onde a base for consentimento.
- DPA, subprocessadores e localização de dados documentados em oferta SaaS.
- Analytics de produto sem comandos, domínios ou segredos em texto livre; preferir eventos estruturados.

13. Requisitos não funcionais

ID	Requisito
NFR-AVAIL-001	Control plane alvo 99,9% mensal em produção; indisponibilidade não afeta sites existentes.
NFR-PERF-001	Páginas principais < 2 s P75 e API de leitura < 400 ms P95, excluindo operações remotas.
NFR-SCALE-001	Arquitetura V1 para 1.000 servidores, 10.000 sites e 100 jobs concorrentes, validada por teste de carga.
NFR-AGENT-001	Heartbeat configurável de 30-60 s; consumo ocioso alvo < 50 MB RAM e CPU desprezível.
NFR-JOB-001	Eventos de progresso visíveis em até 2 s após emissão; reconexão sem perder sequência.
NFR-REL-001	Nenhum job pode terminar succeeded sem verificação final registrada.
NFR-DATA-001	RPO control plane <= 15 min e RTO <= 4 h no MVP; metas revisadas para SaaS pago.
NFR-SEC-001	OWASP ASVS nível 2 como referência e controles adicionais para agente privilegiado.
NFR-A11Y-001	WCAG 2.2 AA nas jornadas principais.
NFR-I18N-001	Strings externalizadas; pt-BR inicial; datas/timezones explícitos.
NFR-COMPAT-001	Chrome/Edge/Firefox/Safari nas duas versões estáveis recentes; agente amd64/arm64 conforme matriz.
NFR-MAINT-001	Migrations backward-compatible em rollout; feature flags para recursos de risco.
NFR-AUD-001	Audit events não editáveis por usuários comuns e exportáveis em CSV/JSON.
NFR-OBS-001	100% dos jobs com correlation ID em API, worker, agente e logs.

13.1 SLOs operacionais sugeridos

Indicador	Meta inicial
Sucesso de heartbeat	>= 99,5% por agente saudável, excluindo manutenção.
Jobs sem erro de plataforma	>= 99,0%; erros de DNS/app separados de erros internos.
Provisionamento de WordPress	P50 < 4 min; P95 < 10 min em infraestrutura compatível.
Deteção de servidor offline	<= 3 minutos após perda de heartbeat.
Alerta de SSL	30, 14, 7 e 3 dias antes da expiração; imediato em renewal failure.
Backup manual	Início < 30 s; duração depende do tamanho e é reportada.

14. Observabilidade, suporte e operação

14.1 Telemetria

Tipo	Exemplos	Cuidados
Métricas	latência API, jobs por estado, queue depth, heartbeat, CPU/RAM/disco, SSL e backups.	Evitar cardinalidade alta por domínio em métricas globais.
Logs	request, worker, agent, security, audit e integration delivery.	JSON estruturado; redaction; correlation_id; retenção.
Traces	request → worker → agent → step → verification.	Amostragem maior em erro; sem secrets nos attributes.
Eventos de produto	wizard_started/completed, job_retry, integration_connected.	Sem domínio, senha ou comando bruto; IDs pseudônimos.

14.2 Alertas internos

- Fila crescendo, worker parado, taxa de falha, PostgreSQL/Redis, storage, expiração de certificados do control plane e agentes.
- Versão de agente incompatível, falha de auto-update, clock drift e inventory stale.
- Segredos/KMS indisponíveis, webhook backlog e e-mail delivery failure.
- Erros de autorização anormais, tentativas de replay e volume de bootstrap tokens.

14.3 Suporte e diagnóstico

- Cada job gera bundle de suporte redigido com versões, etapas, códigos e últimos probes.
- UI oferece “Copiar ID de diagnóstico” e exportação do bundle mediante permissão.
- Runbooks por código de erro: DNS_MISMATCH, WO_UNSUPPORTED, NGINX_CONFIG_FAILED, PHP_FPM_DOWN, SSL_CHALLENGE_FAILED, DISK_LOW, BACKUP_FAILED, AGENT_OFFLINE.
- Feature para suporte nunca deve liberar shell geral; ações excepcionais usam comandos versionados e auditados.

15. Estratégia de testes e qualidade

15.1 Pirâmide de testes

Nível	Cobertura
Unitário	Schemas, policies, command builders, parsers, redaction, state machines e autorização.
Contrato	OpenAPI/SDK, control plane-agent, eventos SSE e versionamento de capabilities.
Integração	PostgreSQL, Redis, object storage, KMS mock e workers.
Agent integration	VMs descartáveis com Ubuntu/Debian e matrizes WordOps/PHP; comandos reais.
E2E	Onboarding, criar site, PHP, cache, SSL, acesso, backup/restore e exclusão.
Segurança	SAST/DAST, dependency/secret scan, fuzz de inputs, privilege tests e pentest.
Resiliência	Queda de agente, timeout, restart do worker, job duplicado, storage indisponível e disco cheio.
UX/A11y	Testes moderados, axe/Playwright, teclado, leitor de tela e contraste.

15.2 Matriz mínima de compatibilidade

- Ubuntu LTS e Debian atualmente suportados pelo WordOps, confirmados por capability discovery e pipeline de VMs.
- WordOps stable atual, stable anterior suportada e canal beta opcional.
- PHPs efetivamente anunciados pelo agente; testes de mudança entre versões adjacentes e downgrade permitido.
- Sites HTML, PHP, MySQL, WordPress sem cache, FastCGI e Redis no MVP.
- Cloudflare token válido/inválido, DNS correto/incorreto, domínio/subdomínio e certificado existente.
- ProFTPD instalado/ausente, username duplicado, path inválido e permissão quebrada.

15.3 Casos de teste críticos

ID	Cenário
TC-001	Dois cliques/requests de criar site com mesma idempotency key geram um único job.
TC-002	Payload com domínio contendo shell metacharacter é rejeitado em API e agente.
TC-003	Operator não consegue purge stack nem acessar site não atribuído.
TC-004	Senha não aparece em DB de logs, traces, audit, SSE ou bundle de suporte.
TC-005	Agente offline impede nova execução e preserva job queued/waiting sem falso sucesso.
TC-006	Alteração PHP falha em Nginx test e termina failed; configuração observada é reconciliada.
TC-007	Acesso FTPS criado em Site A não lê Site B.
TC-008	Backup marcado available somente após checksum e leitura.
TC-009	Job replay assinado após expiração é rejeitado.
TC-010	Exclusão sem typed confirmation/re-auth não inicia.

16. Deploy, CI/CD e ambientes

16.1 Monorepo sugerido

```

opspanel/
  apps/
    web/           # Next.js
    api/           # NestJS/Fastify
    worker/        # processadores de jobs
    agent/         # Go
  packages/
    ui/            # design system
    contracts/     # schemas e tipos versionados
    authz/         # policies/RBAC
    wordops-adapter/ # catálogo, parsers e fixtures
    observability/
  infra/
    docker/
    terraform/
    helm/          # somente quando necessário
  docs/
    adr/
    runbooks/
    openapi/

```

16.2 Ambientes

Ambiente	Objetivo
Local	Docker Compose com Postgres, Redis, MinIO e mocks; agente em VM separada.
Preview	Uma instância por PR para web/API; sem agente produtivo; dados sintéticos.
Staging	Espelho lógico da produção com 2-3 VMs WordOps descartáveis e providers de teste.
Production	Alta disponibilidade proporcional ao plano; backups, alertas, WAF e KMS reais.

16.3 Pipeline

1. Lint, typecheck, unit tests e validação de migrations/contracts.
2. SAST, dependency/secret scan, SBOM e scan de containers/binários.
3. Build imutável com versão e commit; assinatura do agente e instalador.
4. Integration/contract tests e E2E em VMs WordOps para mudanças do adapter/agente.
5. Deploy staging, smoke tests e aprovação para produção.
6. Rollout canary do control plane; migrations expand/contract; feature flags.
7. Agente por canal, rollout pequeno, health gate e rollback automático da versão do binário - não das operações de servidor.

16.4 Configuração e variáveis

- Configuração não secreta por ambiente; secrets em secret manager, nunca no repositório ou imagem.
- URLs públicas, origins, database/redis, KMS, SMTP, storage e signing keys separados.
- Feature flags para wildcard SSL, maintenance e SFTP até maturidade comprovada.
- Migrations executadas por job único; aplicação não deve auto-migrar concorrente.

17. Métricas de produto e SLOs

17.1 North Star e indicadores

Métrica	Definição	Meta inicial
Operações concluídas com segurança	Jobs de valor concluídos e verificados sem intervenção manual.	Crescimento semanal; $\geq 95\%$ das operações elegíveis.
Time to provision	Solicitação até site validado.	P50 < 4 min em ambiente compatível.
Taxa de sucesso	Jobs concluídos / jobs iniciados, segmentado por causa.	$\geq 98\%$ excluindo preflight bloqueado e erro externo.
Intervenção SSH	Percentual de tarefas elegíveis que exigiram SSH manual.	$< 10\%$ após maturação do MVP.
Adoção por operador	Operadores ativos que completam ao menos 3 jobs/semana.	Validar no piloto.
MTTD/MTTR operacional	Tempo para detectar e resolver falha de job/servidor.	Redução contínua; baseline no piloto.

17.2 Eventos de analytics

- server_bootstrap_started/completed/failed; inventory_imported; capability_changed.
- site_wizard_started/step_completed/abandoned; site_create_requested/succeeded/failed.
- php_change_requested; ssl_issue; access_user_created; backup_created/restored.
- job_retry_requested; diagnosis_opened; support_bundle_exported.
- Nunca incluir domínio, IP, username, senha, comando bruto ou conteúdo de log no payload de analytics.

18. Roadmap e backlog priorizado

18.1 Plano de entrega sugerido

Fase	Duração indicativa	Entregas
0. Discovery validada	2 semanas	Entrevistas, protótipo de fluxos, ADRs, threat model e ambiente WordOps de teste.
1. Fundação	2-3 semanas	Monorepo, auth/org/RBAC, DB, audit, design system, API e esqueleto do agente.
2. Servidores e inventário	2-3 semanas	Bootstrap, mTLS, heartbeat, capabilities, reconcile, dashboard e server detail.
3. Sites e jobs	3-4 semanas	Site list/detail, job engine, create wizard, PHP/cache/SSL e logs.
4. Acesso e backup	2-3 semanas	FTPS, secrets, backup pré-op/manual, restore básico, Cloudflare/S3.
5. Hardening e piloto	2-3 semanas	E2E/VM matrix, segurança, a11y, observabilidade, runbooks e piloto.

Estimativa total de MVP: aproximadamente 13-18 semanas para uma equipe experiente. A duração depende do nível de acabamento, integrações, infraestrutura e maturidade desejada para segurança do agente.

18.2 Equipe mínima recomendada

- 1 Product Manager/PO com domínio operacional; 1 UX/UI designer; 1 tech lead/backend; 1 frontend; 1 engenheiro Go/DevOps; QA automation compartilhado; segurança em checkpoints.
- Em equipe menor, backend/tech lead e Go/DevOps podem ser a mesma pessoa, mas o agente privilegiado exige revisão por pares.

18.3 Backlog por épico

Épico	Nome	Pri.	Resultado
E01	Auth e organização	P0	Login, MFA, convites, papéis, sessões e audit.
E02	Design system	P0	Tokens, shell, tables, forms, status, job timeline, danger flows.
E03	Agente bootstrap	P0	Installer, mTLS, registration, heartbeat, update channel.
E04	Capability discovery	P0	OS, WordOps, PHP, stacks, services, paths e versionamento.
E05	Servidor e dashboard	P0	List/detail, health, tags, alerts e reconcile.
E06	Job engine	P0	Queue, locks, idempotency, steps, SSE, retry e diagnostics.
E07	Inventário de sites	P0	Import, list/search, detail e drift.
E08	Criar site	P0	Wizard, adapters HTML/PHP/MySQL/WP, preview e verification.
E09	PHP e cache	P0	Update, preflight, backup e health check.
E10	SSL	P0	Let's Encrypt, DNS preflight, HSTS e expiry alerts.
E11	Acesso de arquivos	P0	FTPS, isolation, password lifecycle e expiry.

Épico	Nome	Pri.	Resultado
E12	Backups	P0/P1	Pre-op, manual, S3/Restic e restore.
E13	Integrações	P1	Cloudflare, S3, SMTP, webhook.
E14	Maintenance	P1	Stacks, WordOps update, approvals e windows.
E15	Public API	P1	API keys, scopes, docs e idempotency.
E16	Hardening	P0	Threat controls, redaction, testing matrix e pentest.

19. Riscos e mitigação

Risco	Severidade	Mitigação
Agente root amplia impacto de vulnerabilidade	Crítico	Allowlist tipada, mTLS, assinatura, privilege separation futura, auditoria, pentest e sem porta inbound.
Saída CLI muda entre versões	Alto	Capability/adapter versionado, fixtures por versão, verificação por estado e matriz de testes.
WordOps/documentação e releases evoluem em ritmos diferentes	Alto	Não hardcode; discovery real; support policy; feature flags e mensagens de incompatibilidade.
Alteração PHP/cache quebra aplicação	Alto	Backup, baseline, health checks, confirmação e retorno como novo job.
Permissões FTPS causam escrita insegura ou cross-site	Crítico	ACL testada, no shell, protocolo TLS, username global, testes de isolamento e defaults conservadores.
SSL depende de DNS e portas externas	Médio	Preflight explícito, provider integration e diagnóstico por código.
Backup existe mas não restaura	Alto	Checksum, leitura, restore drills e métricas de sucesso de restauração.
Glassmorphism reduz legibilidade	Médio	Superfícies opacas para dados, contraste AA e reduced transparency.
Escopo vira cPanel completo	Alto	Product principles, não objetivos e backlog por fases.
Uso público do nome WordOps sugere produto oficial	Médio	Nome próprio e comunicação "compatível com WordOps"; revisão jurídica/marca antes do lançamento.

20. Critérios de lançamento e Definition of Done

20.1 MVP pronto para piloto quando

- Três servidores reais/descarte conectam via agente e permanecem estáveis por 14 dias.
- Importação de sites existentes não modifica servidor e reconcilia inventário corretamente.
- Fluxos P0 passam em E2E na matriz mínima de OS/WordOps/PHP.
- Não há segredo detectável em logs, traces, audit, errors, analytics ou artefatos de teste.
- Pentest e threat review não apresentam vulnerabilidade crítica/alta sem mitigação aprovada.
- Backups pré-operação e restore básico foram testados com sucesso.
- RBAC e isolamento cross-tenant/site têm testes negativos automatizados.
- Dashboard e fluxos críticos passam em auditoria WCAG AA sem bloqueadores.
- Runbooks, alertas, backup do control plane e procedimento de rollback de release estão documentados.
- Piloto tem owner definido, suporte, critérios de parada e coleta de feedback.

20.2 Definition of Done por story

- Critérios funcionais e de erro implementados; permissão verificada na UI, API e agente quando aplicável.
- Testes unitários/integração/E2E adequados; fixtures e documentação atualizadas.
- Logs estruturados, métricas, trace e audit event definidos; redaction validada.
- Empty/loading/error/success e teclado/a11y revisados.
- Migrations reversíveis/compatíveis; feature flag quando risco elevado.
- Runbook ou diagnóstico atualizado para novas falhas operacionais.
- Code review por pelo menos um engenheiro diferente; revisão de segurança para adapters privilegiados.

21. Decisões em aberto para fechar antes do desenvolvimento

Decisão	Pergunta / recomendação
Modelo comercial	Ferramenta interna, SaaS público, licença self-hosted ou híbrido? Define tenant, billing, suporte e compliance.
Nome e marca	OpsPanel é provisório. Evitar nome que pareça dashboard oficial do WordOps sem autorização.
Primeiro protocolo de acesso	FTPS via ProFTPD alinhado ao ecossistema WordOps ou SFTP chrooted como prioridade? Recomendação: FTPS seguro no MVP e SFTP em V1 após testes.
Armazenamento de senha	Painel guarda credenciais de site como vault opcional ou apenas revela uma vez? Recomendação: revelar uma vez por padrão; vault opt-in.
Cloud vs self-hosted	Onde roda o control plane e quem opera backups/KMS? Arquitetura suporta ambos, mas packaging muda.
Approval workflow	Quais ações exigem segundo aprovador: exclusão, maintenance, instalação de stack, restore?
Backup MVP	Backup apenas pré-op/local ou já remoto/S3? Recomendação: pré-op + manual remoto para reduzir risco real.
Limites do editor Nginx	Somente leitura no MVP; snippets versionados no futuro ou editor avançado?
Suporte a PHP legado	Política de versões EOL: mostrar com alerta, bloquear novas instalações ou permitir por exceção?
Escala inicial	Quantidade esperada de servidores/sites e frequência de métricas para dimensionar ingestão.

Recomendação prática

Começar o design de alta fidelidade e a arquitetura com as premissas deste documento. As decisões acima podem virar feature flags ou ADRs; não é necessário travar todo o projeto para iniciar o protótipo e o spike do agente.

22. Prompt mestre de implementação

O bloco a seguir pode ser usado como briefing principal em Cursor, Claude Code, Codex, Windsurf ou outra ferramenta de engenharia assistida por IA. Ele não substitui revisão humana, testes em VMs e threat modeling do agente privilegiado.

Você é um time sênior de Product Engineering composto por Product Manager, UX/UI Designer, Tech Lead, Frontend, Backend, Go/Systems, DevOps/SRE, QA e Application Security.

OBJETIVO

Construir o MVP do “OpsPanel”, uma plataforma web moderna para administrar múltiplos servidores que usam WordOps. O painel deve importar sites existentes e automatizar, por fluxos guiados, operações como criação de sites, seleção de stack/cache, mudança de PHP, SSL/HSTS, habilitar/desabilitar, acesso de arquivos por site, backups, logs e auditoria.

PRINCÍPIO INEGOCIÁVEL

Não crie terminal web nem endpoint que aceite shell/comando arbitrário. Todas as mudanças são operações tipadas, validadas e versionadas, executadas por um agente Go local no servidor. O agente mantém conexão outbound mTLS, aceita somente catálogo allowlist, redige segredos e verifica o estado final.

ARQUITETURA

- Monorepo: apps/web (Next.js/React/TypeScript), apps/api (NestJS + Fastify), apps/worker, apps/agent (Go), packages/ui, packages/contracts, packages/authz, packages/wordops-adapter e infra.
- PostgreSQL como estado definitivo; Redis/BullMQ para fila/coordenação; S3-compatible para backups; KMS/Vault ou envelope encryption para segredos; SSE para logs/progresso.
- Docker Compose para local/MVP. Não introduza Kubernetes sem necessidade comprovada.
- OpenAPI versionada, UUIDv7, timestamps UTC, Problem Details, Idempotency-Key em mutações.

MÓDULOS MVP P0

1. Auth, e-mail verificado, MFA TOTP, recovery, organização, convites, RBAC e audit log.
2. Bootstrap de agente por token de uso único; mTLS; heartbeat; revogação e auto-update assinado.
3. Capability discovery: OS, WordOps/version, PHPs, stacks, services, resources e sites.
4. Dashboard, servidores, saúde, alertas, inventário e busca global.
5. Job engine: state machine, steps, locks, idempotência, retry seguro, timeout, SSE, redaction, diagnostics e independent verification.
6. Sites: import/list/detail; create HTML, PHP, PHP+MySQL e WordPress; cache none/fastcgi/redis; PHP disponível; SSL Let's Encrypt; HSTS; enable/disable; delete protegido.
7. Mudança de PHP/cache com preflight, backup obrigatório e health check.
8. Acesso de arquivos: FTPS via ProFTPD no MVP, sem shell, restrito ao site, expiração, senha forte revelada uma vez, rotate/revoke e proibição de FTP sem TLS.
9. Backup pré-operação e manual; integração S3-compatible/Restic; restore básico.
10. Notificações, Cloudflare, secrets, logs e observabilidade.

UX/UI

- Seguir referência glassmorphism: degradê pêssego/cinza, shell translúcida, bordas claras, cantos 20px, cards claros e card escuro para jobs/logs.
- Tipografia Geist/Inter; texto #162237; accent #C96D3A; dark #171717.
- Desktop-first responsivo, sidebar, header, grid 12 colunas, tabelas legíveis e drawers.
- WCAG 2.2 AA. Glass não pode reduzir contraste. Estados sempre usam ícone + texto + cor.
- Padrão de operação: preflight > review/preview > execute > verify > result.
- Criar telas S01-S20 descritas no PRD, começando por dashboard, servers, sites, create-site wizard, site detail, job detail, access users e backups.

SEGURANÇA

- Subprocess argv; nunca sh -c com input externo.
- Validação no API e agente; domain/username/path/flags em allowlist; impedir traversal/symlink escape.
- Secret refs; nenhuma senha/token em logs, traces, audit, analytics, errors ou URLs.
- MFA, reauth para destrutivos, deny-by-default, object-level authorization, rate limit.
- Agent jobs assinados, expirados, anti-replay e tenant-bound.
- Supply chain: SBOM, assinatura de binário/installer, checksum, scans e fixtures por versão.

WORDOPS ADAPTER

- Implementar catálogo versionado para: inventory, site list/info/create/update, PHP/cache/SSL, enable/disable/delete, stack/service actions allowlisted.
- Não hardcode versões PHP; usar capabilities reais. Tratar mudanças de output por adapter/fixture.
- Usar WordOps CLI somente como mecanismo; confirmar resultado por probes independentes: site info, filesystem, nginx -t, systemd e HTTP/HTTPS.
- Senhas personalizadas não devem aparecer no comando exibido. Preferir senha gerada e alteração posterior via mecanismo que use stdin/prompt quando suportado.

ENTREGAS POR MILESTONE

M0: ADRs, schemas, threat model, design tokens, repo e Compose.
M1: Auth/org/RBAC/audit + design system + API base.
M2: Agent bootstrap/mTLS/heartbeat/capabilities/inventory.
M3: Job engine/SSE/locks/redaction + server/site list/detail.
M4: Create-site wizard + WordOps adapters + verification.
M5: PHP/cache/SSL/access/backup + integrations.
M6: E2E VM matrix, security hardening, ally, runbooks e pilot release.

PARA CADA MILESTONE

- Apresente plano e arquivos a criar antes de codificar.
- Implemente migrations, schemas, API, UI, tests, fixtures, telemetry e docs juntos.
- Não use mocks como conclusão de feature; marque claramente adapters ainda não reais.
- Inclua comandos de execução local, seed sem dados sensíveis e testes reproduzíveis.
- Pare e sinalize qualquer decisão que possa criar acesso root amplo, vazamento de segredo, perda de dados ou incompatibilidade WordOps. Não improvise atalhos inseguros.

CRITÉRIOS DE ACEITE

Use os IDs FR/NFR, fluxos, estados, endpoints, modelo de dados, threat controls e Definition of Done do PRD OpsPanel v1.0 como fonte normativa. Em caso de conflito, segurança e preservação de dados têm prioridade sobre conveniência visual ou velocidade de entrega.

Apêndice A - Mapa de capacidades WordOps para adapters

Este mapa traduz recursos oficiais do WordOps em operações de produto. A lista exata deve ser confirmada por `--help`, versão e capability discovery em cada servidor; a documentação pode ficar atrás do código atual.

Capacidade	Comando/flag	Tratamento no produto
Inventário de sites	wo site list	Somente leitura; complementar com site info por domínio.
Detalhe de site	wo site info <domain>	Parse estruturado e verificação de paths/config.
Mostrar Nginx	wo site show <domain>	Leitura sanitizada; não expor includes sensíveis.
Criar HTML	wo site create <domain> --html	Wizard tipo HTML.
Criar PHP	wo site create <domain> --php ou --phpXX	PHP sem banco.
Criar PHP+DB	wo site create <domain> --mysql	Credenciais em wo-config; tratar como segredo.
Criar WordPress	--wp	Sem page cache.
FastCGI	--wpfc	Nginx FastCGI cache.
Redis	--wpreis	Cache Redis conforme WordOps.
Outros caches	--wpse / --wprocket / --wpce	P1 conforme compatibilidade e licença/plugin.
Multisite	--wpsubdir / --wpsubdomain	V1; wildcard pode exigir DNS challenge.
Vhost only	--vhostonly	V1; cria estrutura sem instalação completa.
Proxy	--proxy=<destino>	V1; validar host/porta e SSRF/local policy.
Alias	--alias <target>	V1; validar loop e domínio alvo.
Subsite	--subsiteof <multisite>	V1, dependendo da versão.
SSL	--letsencrypt / -le	Preflight DNS/ports.
Wildcard	--letsencrypt=wildcard --dns=<provider>	P1; segredo DNS e acme capabilities.
HSTS	--hsts / --hsts=off	Aviso forte.
PHP update	wo site update <domain> --phpXX	Backup + health check.
Cache update	wo site update <domain> --wp*	Validar transição.
Enable/disable	wo site enable/disable <domain>	Confirmar Nginx.
Delete	wo site delete <domain> [--files --db]	Destrutivo, backup e typed confirmation.
Stacks	wo stack install/upgrade/reload/restart/status	P1 e allowlist; purge bloqueado.
Maintenance	wo maintenance / wo update	Janela e approval.
FTP stack	wo stack install --proftpd	Conta de acesso é operação local adicional.

Apêndice B - Exemplos de payloads e erros

B.1 Solicitação de mudança de PHP

```
POST /api/v1/sites/site_123/operations/php
Idempotency-Key: 018f...

{
  "target_php_version": "8.4",
  "install_if_missing": false,
  "backup_policy": "required",
  "verification": {
    "http_paths": ["/", "/wp-login.php"],
    "expected_status": [200, 301, 302]
  },
  "reason": "Compatibilidade do plugin X"
}
```

B.2 Resposta assíncrona

```
202 Accepted
{
  "job_id": "job_01J...",
  "state": "requested",
  "target": {"type": "site", "id": "site_123"},
  "links": {
    "self": "/api/v1/jobs/job_01J...",
    "events": "/api/v1/jobs/job_01J.../events"
  }
}
```

B.3 Erro padronizado

```
409 Conflict
{
  "type": "https://docs.opspanel/errors/resource-locked",
  "title": "O site já possui uma operação em andamento",
  "status": 409,
  "code": "SITE_OPERATION_LOCKED",
  "detail": "Aguarde o job job_01J... concluir ou falhar.",
  "correlation_id": "cor_01J..."
}
```

B.4 Evento SSE

```
id: 42
event: job.step.progress
data: {"job_id":"job_01J...","step":"nginx_verify","progress":82}
data: {"message":"Validando configuração Nginx"}
```

Apêndice C - Glossário e referências oficiais

C.1 Glossário

Termo	Definição
Control plane	Aplicação central que armazena estado, aplica autorização e orquestra operações.
Agent	Serviço local que descobre capabilities e executa operações tipadas no servidor.
Capability	Recurso observado e versionado: PHP disponível, stack instalada, OS e opções suportadas.
Desired state	Configuração pretendida pelo produto/usuário.
Observed state	Configuração realmente detectada no servidor.
Reconciliation	Comparação e atualização entre estado observado e cadastro do painel.
Job	Operação assíncrona com etapas, estado, locks, logs e verificação.
Adapter	Código que traduz operação de domínio para WordOps/sistema e interpreta resultados.
Preflight	Validações feitas imediatamente antes de executar mudança.
Secret reference	Identificador de segredo criptografado, sem revelar o valor em payloads comuns.
FTPS	FTP protegido por TLS; não confundir com SFTP.
SFTP	Transferência via SSH; requer modelo de isolamento diferente.

C.2 Fontes técnicas consultadas

ID	Fonte	URL
WO-01	Repositório oficial WordOps/WordOps	https://github.com/WordOps/WordOps
WO-02	Documentação - comandos de site	https://docs.wordops.net/commands/site/
WO-03	Documentação - comandos de stack	https://docs.wordops.net/commands/stack/
WO-04	Documentação - visão geral de comandos	https://docs.wordops.net/commands/
WO-05	Documentação - instalação	https://docs.wordops.net/getting-started/installation-guide/
WO-06	Documentação - adicionar usuários FTP	https://docs.wordops.net/how-to/add-ftp-users/
WO-07	Documentação - criação de sites	https://docs.wordops.net/getting-started/creating-sites/
WO-08	Releases oficiais	https://github.com/WordOps/WordOps/releases

Encerramento

Este PRD define um caminho completo para transformar o WordOps em uma experiência visual moderna sem sacrificar segurança, rastreabilidade ou fidelidade ao estado real do servidor.

A próxima etapa recomendada é produzir o protótipo de alta fidelidade das oito telas centrais - Dashboard, Servidores, Detalhe do servidor, Sites, Criar site, Detalhe do site, Job e Acesso - em paralelo a um spike técnico do agente com três operações: `inventory`, `site.create` e `site.update.php`. O resultado do spike deve validar parsing, redaction, locks, mTLS e verificação independente antes de ampliar o catálogo.